دليل استغلال الثغرات

Vulnerability Exploitation Walkthrough

🎯 https://0a650022042123ab80198a0b00070026.w
/eb-security-academy.net

📅 ١٥ يناير ٢٠٢٦ في ٠٤:٤٤ م

5	11	2	11
حرجة	عالية	متوسطة	منخفضة

📋 جدول المحتويات

1. Missing Security Header	عالية
2. Missing Security Header	متوسطة
3. Missing Security Header	متوسطة
4. Missing Security Header	منخفضة
5. Missing Security Header	منخفضة
6. Missing Security Header	منخفضة
7. Sensitive Data Exposure	حرجة
8. XSS	منخفضة
9. XSS	منخفضة
10. XSS	منخفضة
11. XSS	منخفضة
12. SQL Injection	حرجة
13. SQL Injection	حرجة
14. SQL Injection	حرجة
15. SQL Injection	حرجة
16. SSRF	عالية
17. SSRF	عالية

SSRF .18	عالية
SSRF .19	عالية
IDOR .20	عالية
IDOR .21	عالية
IDOR .22	عالية
IDOR .23	عالية
IDOR .24	عالية
IDOR .25	عالية
Open Redirect .26	منخفضة
Open Redirect .27	منخفضة
Open Redirect .28	منخفضة
Open Redirect .29	منخفضة

ثغرة رقم 1

Missing Security Header

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

HTTP Strict Transport Security (HSTS) not set

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

فحص الـ Headers

تم فحص headers الاستجابة للبحث عن مشاكل أمنية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

تحليل المشكلة

HTTP Strict Transport Security (HSTS) not set

التفاصيل

```
Header "strict-transport-security" not found in response
```

⚠️ الدليل (Evidence)

```
Header "strict-transport-security" not found in response
```

💻 أمر cURL للإعادة

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Set Strict-Transport-Security header with max-age of at least 31536000 (1 year)

📚 مراجع إضافية

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

ثغرة رقم 2

Missing Security Header

الخطورة: **متوسطة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

X-Content-Type-Options header not set

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

فحص الـ Headers

تم فحص headers الاستجابة للبحث عن مشاكل أمنية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

تحليل المشكلة

X-Content-Type-Options header not set

التفاصيل

```
Header "x-content-type-options" not found in response
```

⚠️ الدليل (Evidence)

```
Header "x-content-type-options" not found in response
```

💻 أمر cURL للإعادة

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Set X-Content-Type-Options: nosniff

📚 مراجع إضافية

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

ثغرة رقم 3

Missing Security Header

الخطورة: **متوسطة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Content-Security-Policy header not set

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

فحص الـ Headers

تم فحص الاستجابة للبحث عن مشاكل أمنية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

تحليل المشكلة

Content-Security-Policy header not set

التفاصيل

```
Header "content-security-policy" not found in response
```

⚠️ الدليل (Evidence)

```
Header "content-security-policy" not found in response
```

💻 أمر cURL للإعادة

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement a strict Content Security Policy

📚 مراجع إضافية

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

ثغرة رقم 4

Missing Security Header

الخطورة: منخفضة | الثقة: 0% | الفئة: عام

📖 وصف الثغرة

X-XSS-Protection header not set (legacy but still useful)

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

فحص الـ Headers

تم فحص headers الاستجابة للبحث عن مشاكل أمنية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

تحليل المشكلة

X-XSS-Protection header not set (legacy but still useful)

التفاصيل

```
Header "x-xss-protection" not found in response
```

⚠️ الدليل (Evidence)

```
Header "x-xss-protection" not found in response
```

💻 أمر cURL للإعادة

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Set X-XSS-Protection: 1; mode=block

📚 مراجع إضافية

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

ثغرة رقم 5

Missing Security Header

الخطورة: **منخفضة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Referrer-Policy header not set

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

فحص الـ Headers

تم فحص الاستجابة للبحث عن مشاكل أمنية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

تحليل المشكلة

Referrer-Policy header not set

التفاصيل

```
Header "referrer-policy" not found in response
```

⚠️ الدليل (Evidence)

```
Header "referrer-policy" not found in response
```

💻 أمر cURL للإعادة

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Set Referrer-Policy: strict-origin-when-cross-origin

📚 مراجع إضافية

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

ثغرة رقم 6

Missing Security Header

الخطورة: منخفضة | الثقة: 0% | الفئة: عام

📖 وصف الثغرة

Permissions-Policy header not set

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

فحص الـ Headers

تم فحص الاستجابة للبحث عن مشاكل أمنية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

تحليل المشكلة

Permissions-Policy header not set

التفاصيل

```
Header "permissions-policy" not found in response
```

⚠️ الدليل (Evidence)

```
Header "permissions-policy" not found in response
```

💻 أمر cURL للإعادة

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Define a Permissions-Policy to control browser features

📚 مراجع إضافية

https://owasp.org/www-project-secure-headers/

https://securityheaders.com/

ثغرة رقم 7

Sensitive Data Exposure

الخطورة: **حرجة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

.AWS Secret Key exposed in response. This could allow unauthorized access to services

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/
```

2

التحليل

.AWS Secret Key exposed in response. This could allow unauthorized access to services

الدليل

```
Found AWS Secret Key: href****yLab
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ **الدليل (Evidence)**

```
Found AWS Secret Key: href****yLab
```

💻 **أمر cURL للإعادة**

```
curl -X GET "https://0a650022042123ab80198a0b00070026.web-security-academy.net/"
```

💥 **التأثير المحتمل**

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ **كيفية الإصلاح**

.Remove API keys from client-side code. Use environment variables and server-side proxies

📚 **مراجع إضافية**

https://owasp.org/www-community/vulnerabilities/Use_of_hard-coded_password

ثغرة رقم 8

XSS

الخطورة: **منخفضة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل (parameter) يعكس المدخلات في الصفحة بدون تصفية كافية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

اختبار الحقن الأساسي

تم إرسال payload بسيط لاختبار إمكانية تنفيذ JavaScript.

Payload

```
<math><maction actiontype="statusline#http://evil.com" xlink:href="javasc
ript:alert(1)">
```

3

التحقق من التنفيذ

تم التأكد من أن الكود تم تنفيذه في المتصفح عن طريق ملاحظة الاستجابة.

النتيجة

```
...statusline#http://evil.com&quot; xlink:href=&quot;javascript:alert(1)&
quot;&gt;</h1>
                    </sect...
```

4

تحليل السياق

تحديد السياق الذي يظهر فيه الـ payload (HTML, JavaScript, Attribute).

التحليل

```
السياق: HTML Body
```

⚠️ الدليل (Evidence)

```
...statusline#http://evil.com&quot; xlink:href=&quot;javascript:alert(1)&
quot;&gt;</h1>
                    </sect...
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/fi
lter?category=Clothing%2c+shoes+and+accessories"
```

💥 التأثير المحتمل

يمكن للمهاجم سرقة cookies الجلسة، تنفيذ إجراءات نيابة عن المستخدم، سرقة بيانات حساسة، أو توجيه المستخدمين لمواقع ضارة.

✅ كيفية الإصلاح

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

📚 مراجع إضافية

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

---

ثغرة رقم 9

XSS

الخطورة: **منخفضة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل (parameter) يعكس المدخلات في الصفحة بدون تصفية كافية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

2

اختبار الحقن الأساسي

تم إرسال payload بسيط لاختبار إمكانية تنفيذ JavaScript.

Payload

```
"><img src=x onerror=alert(1)>
```

3

التحقق من التنفيذ

تم التأكد من أن الكود تم تنفيذه في المتصفح عن طريق ملاحظة الاستجابة.

النتيجة

```
...                    <h1>&quot;&gt;&lt;img src=x onerror=alert(1)&gt;
</h1>
                    </section>
 ...
```

4

تحليل السياق

تحديد السياق الذي يظهر فيه الـ payload (HTML, JavaScript, Attribute).

التحليل

```
السياق: HTML Body
```

⚠️ **الدليل (Evidence)**

```
...                    <h1>&quot;&gt;&lt;img src=x onerror=alert(1)&gt;
</h1>
                    </section>
 ...
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink"
```

💥 **التأثير المحتمل**

يمكن للمهاجم سرقة cookies الجلسة، تنفيذ إجراءات نيابة عن المستخدم، سرقة بيانات حساسة، أو توجيه المستخدمين لمواقع ضارة.

✅ كيفية الإصلاح

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

📚 مراجع إضافية

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

---

ثغرة رقم 10

XSS

الخطورة: **منخفضة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل (parameter) يعكس المدخلات في الصفحة بدون تصفية كافية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

2

اختبار الحقن الأساسي

تم إرسال payload بسيط لاختبار إمكانية تنفيذ JavaScript.

Payload

```
<script>alert(1)</script>
```

3

التحقق من التنفيذ

تم التأكد من أن الكود تم تنفيذه في المتصفح عن طريق ملاحظة الاستجابة.

النتيجة

```
...idden data</title>
    </head>
    <body>
        <script src="/resources/labheader/js/labHeader.js"></scri...
```

4

تحليل السياق

تحديد السياق الذي يظهر فيه الـ payload (HTML, JavaScript, Attribute).

التحليل

```
السياق: HTML Body
```

⚠️ **الدليل (Evidence)**

```
...idden data</title>
    </head>
    <body>
        <script src="/resources/labheader/js/labHeader.js"></scri...
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle"
```

💥 **التأثير المحتمل**

يمكن للمهاجم سرقة cookies الجلسة، تنفيذ إجراءات نيابة عن المستخدم، سرقة بيانات حساسة، أو توجيه المستخدمين لمواقع ضارة.

✅ كيفية الإصلاح

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

📚 مراجع إضافية

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

---

ثغرة رقم 11

XSS

الخطورة: منخفضة | الثقة: 0% | الفئة: عام

📖 وصف الثغرة

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل (parameter) يعكس المدخلات في الصفحة بدون تصفية كافية.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

2

اختبار الحقن الأساسي

تم إرسال payload بسيط لاختبار إمكانية تنفيذ JavaScript.

Payload

```
<form><button formaction="javascript:alert(1)">click
```

3

التحقق من التنفيذ

تم التأكد من أن الكود تم تنفيذه في المتصفح عن طريق ملاحظة الاستجابة.

النتيجة

```
...      <h1>&lt;form&gt;&lt;button formaction=&quot;javascript:alert(1)&
quot;&gt;click</h1>
                    <...
```

4

تحليل السياق

تحديد السياق الذي يظهر فيه الـ payload (HTML, JavaScript, Attribute).

التحليل

```
السياق: HTML Body
```

⚠️ **الدليل (Evidence)**

```
...      <h1>&lt;form&gt;&lt;button formaction=&quot;javascript:alert(1)&
quot;&gt;click</h1>
                    <...
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/fi
lter?category=Pets"
```

💥 **التأثير المحتمل**

يمكن للمهاجم سرقة cookies الجلسة، تنفيذ إجراءات نيابة عن المستخدم، سرقة بيانات حساسة، أو توجيه المستخدمين لمواقع ضارة.

✅ كيفية الإصلاح

Implement proper input validation and output encoding. Use Content-Security-Policy headers.

📚 مراجع إضافية

https://portswigger.net/web-security/cross-site-scripting

https://owasp.org/www-community/attacks/xss/

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

---

ثغرة رقم 12

SQL Injection

الخطورة: **حرجة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Boolean-based blind SQL Injection detected in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل يتم تمريره مباشرة إلى استعلام SQL.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

2

اختبار الحقن

تم إرسال علامة اقتباس مفردة لاختبار وجود خطأ SQL.

Payload

```
' AND '1'='1
```

3

تحليل الاستجابة

تمت ملاحظة تغير في سلوك التطبيق أو رسالة خطأ SQL.

الدليل

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1162 bytes
```

4

تأكيد الثغرة

تم التأكد من إمكانية التلاعب بالاستعلام.

Payload متقدم

```
UNION SELECT NULL, username, password FROM users--
```

⚠️ الدليل (Evidence)

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1162 bytes
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories"
```

💥 التأثير المحتمل

يمكن للمهاجم قراءة أو تعديل أو حذف بيانات قاعدة البيانات بالكامل، وفي بعض الحالات تنفيذ أوامر على الخادم.

✅ كيفية الإصلاح

.Use parameterized queries. Implement proper input validation

📚 مراجع إضافية

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

ثغرة رقم 13

SQL Injection

الخطورة: **حرجة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Boolean-based blind SQL Injection detected in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل يتم تمريره مباشرة إلى استعلام SQL.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

2

اختبار الحقن

تم إرسال علامة اقتباس مفردة لاختبار وجود خطأ SQL.

Payload

```
' AND '1'='1
```

3

تحليل الاستجابة

تمت ملاحظة تغير في سلوك التطبيق أو رسالة خطأ SQL.

الدليل

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1149 bytes
```

4

تأكيد الثغرة

تم التأكد من إمكانية التلاعب بالاستعلام.

Payload متقدم

```
UNION SELECT NULL, username, password FROM users--
```

⚠️ **الدليل (Evidence)**

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1149 bytes
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink"
```

💥 **التأثير المحتمل**

يمكن للمهاجم قراءة أو تعديل أو حذف بيانات قاعدة البيانات بالكامل، وفي بعض الحالات تنفيذ أوامر على الخادم.

✅ كيفية الإصلاح

.Use parameterized queries. Implement proper input validation

📚 مراجع إضافية

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

ثغرة رقم 14

SQL Injection

الخطورة: **حرجة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Boolean-based blind SQL Injection detected in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل يتم تمريره مباشرة إلى استعلام SQL.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

2

اختبار الحقن

تم إرسال علامة اقتباس مفردة لاختبار وجود خطأ SQL.

Payload

```
' AND '1'='1
```

3

تحليل الاستجابة

تمت ملاحظة تغير في سلوك التطبيق أو رسالة خطأ SQL.

الدليل

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1134 bytes
```

4

تأكيد الثغرة

تم التأكد من إمكانية التلاعب بالاستعلام.

Payload متقدم

```
UNION SELECT NULL, username, password FROM users--
```

⚠️ **الدليل (Evidence)**

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1134 bytes
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle"
```

💥 **التأثير المحتمل**

يمكن للمهاجم قراءة أو تعديل أو حذف بيانات قاعدة البيانات بالكامل، وفي بعض الحالات تنفيذ أوامر على الخادم.

✅ كيفية الإصلاح

.Use parameterized queries. Implement proper input validation

📚 مراجع إضافية

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

ثغرة رقم 15

SQL Injection

الخطورة: **حرجة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

"Boolean-based blind SQL Injection detected in parameter "category

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

🚀 خطوات الاستغلال

1

تحديد نقطة الحقن

تم اكتشاف معامل يتم تمريره مباشرة إلى استعلام SQL.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

2

اختبار الحقن

تم إرسال علامة اقتباس مفردة لاختبار وجود خطأ SQL.

Payload

```
' AND '1'='1
```

3

تحليل الاستجابة

تمت ملاحظة تغير في سلوك التطبيق أو رسالة خطأ SQL.

الدليل

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1148 bytes
```

4

تأكيد الثغرة

تم التأكد من إمكانية التلاعب بالاستعلام.

Payload متقدم

```
UNION SELECT NULL, username, password FROM users--
```

⚠️ الدليل (Evidence)

```
Response length difference detected: TRUE condition similar to baseline,
FALSE condition differs by 1148 bytes
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets"
```

💥 التأثير المحتمل

يمكن للمهاجم قراءة أو تعديل أو حذف بيانات قاعدة البيانات بالكامل، وفي بعض الحالات تنفيذ أوامر على الخادم.

✅ كيفية الإصلاح

.Use parameterized queries. Implement proper input validation

📚 مراجع إضافية

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

ثغرة رقم 16

SSRF

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

🚀 خطوات الاستغلال

1

تحديد وظيفة جلب URL

تم اكتشاف وظيفة تقوم بجلب محتوى من URL خارجي.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

اختبار الوصول الداخلي

تم محاولة الوصول لعناوين داخلية.

Payload

```
http://127.0.0.1
```

3

التأكد من الثغرة

تمت ملاحظة استجابة من الخادم الداخلي.

النتيجة

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

⚠️ **الدليل (Evidence)**

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories"
```

💥 **التأثير المحتمل**

يمكن للمهاجم الوصول لموارد داخلية، قراءة metadata السحابية، أو مهاجمة خدمات داخلية.

✅ **كيفية الإصلاح**

Implement URL validation with allowlists. Block internal IP ranges and cloud metadata .endpoints. Use DNS resolution validation

📚 **مراجع إضافية**

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

/cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

ثغرة رقم 17

SSRF

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

🚀 خطوات الاستغلال

1

تحديد وظيفة جلب URL

تم اكتشاف وظيفة تقوم بجلب محتوى من URL خارجي.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

اختبار الوصول الداخلي

تم محاولة الوصول لعناوين داخلية.

Payload

```
http://127.0.0.1
```

3

التأكد من الثغرة

تمت ملاحظة استجابة من الخادم الداخلي.

النتيجة

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

⚠️ **الدليل (Evidence)**

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink"
```

💥 **التأثير المحتمل**

يمكن للمهاجم الوصول لموارد داخلية، قراءة metadata السحابية، أو مهاجمة خدمات داخلية.

✅ **كيفية الإصلاح**

Implement URL validation with allowlists. Block internal IP ranges and cloud metadata .endpoints. Use DNS resolution validation

📚 **مراجع إضافية**

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

/cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

ثغرة رقم 18

SSRF

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

🚀 خطوات الاستغلال

1

تحديد وظيفة جلب URL

تم اكتشاف وظيفة تقوم بجلب محتوى من URL خارجي.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

اختبار الوصول الداخلي

تم محاولة الوصول لعناوين داخلية.

Payload

```
http://127.0.0.1
```

3

التأكد من الثغرة

تمت ملاحظة استجابة من الخادم الداخلي.

النتيجة

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

⚠️ **الدليل (Evidence)**

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle"
```

💥 **التأثير المحتمل**

يمكن للمهاجم الوصول لموارد داخلية، قراءة metadata السحابية، أو مهاجمة خدمات داخلية.

✅ **كيفية الإصلاح**

Implement URL validation with allowlists. Block internal IP ranges and cloud metadata .endpoints. Use DNS resolution validation

📚 **مراجع إضافية**

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

/cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

ثغرة رقم 19

SSRF

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

🚀 خطوات الاستغلال

1

تحديد وظيفة جلب URL

تم اكتشاف وظيفة تقوم بجلب محتوى من URL خارجي.

URL

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

اختبار الوصول الداخلي

تم محاولة الوصول لعناوين داخلية.

Payload

```
http://127.0.0.1
```

3

التأكد من الثغرة

تمت ملاحظة استجابة من الخادم الداخلي.

النتيجة

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

⚠️ **الدليل (Evidence)**

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets"
```

💥 **التأثير المحتمل**

يمكن للمهاجم الوصول لموارد داخلية، قراءة metadata السحابية، أو مهاجمة خدمات داخلية.

✅ **كيفية الإصلاح**

Implement URL validation with allowlists. Block internal IP ranges and cloud metadata endpoints. Use DNS resolution validation.

📚 **مراجع إضافية**

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

/cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

ثغرة رقم 20

IDOR

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=7
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=7
```

التحليل

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

2

الدليل

```
Response differs by 595 bytes when changing ID from 7 to 6
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
Response differs by 595 bytes when changing ID from 7 to 6
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=7"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

📚 مراجع إضافية

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

ثغرة رقم 21

IDOR

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=12
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=12
```

التحليل

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل

```
Response differs by 108 bytes when changing ID from 12 to 13
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
Response differs by 108 bytes when changing ID from 12 to 13
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=12"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

📚 مراجع إضافية

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

ثغرة رقم 22

IDOR

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=17
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=17
```

التحليل

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

2

الدليل

```
Response differs by 249 bytes when changing ID from 17 to 18
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
Response differs by 249 bytes when changing ID from 17 to 18
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=17"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

📚 مراجع إضافية

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

ثغرة رقم 23

IDOR

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=6
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=6
```

التحليل

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل

```
Response differs by 595 bytes when changing ID from 6 to 7
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
Response differs by 595 bytes when changing ID from 6 to 7
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=6"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

📚 مراجع إضافية

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

ثغرة رقم 24

IDOR

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=11
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=11
```

التحليل

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

2

الدليل

```
Response differs by 150 bytes when changing ID from 11 to 12
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
Response differs by 150 bytes when changing ID from 11 to 12
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=11"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

📚 مراجع إضافية

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

ثغرة رقم 25

IDOR

الخطورة: **عالية** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=16
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=16
```

التحليل

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

2

الدليل

```
Response differs by 187 bytes when changing ID from 16 to 1
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
Response differs by 187 bytes when changing ID from 16 to 1
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/product?productId=16"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

📚 مراجع إضافية

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

ثغرة رقم 26

Open Redirect

الخطورة: منخفضة | الثقة: 0% | الفئة: عام

📖 وصف الثغرة

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

التحليل

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

الدليل

```
External URL reflected in response
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
External URL reflected in response
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

📚 مراجع إضافية

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

ثغرة رقم 27

Open Redirect

الخطورة: **منخفضة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink
```

2

التحليل

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

الدليل

```
External URL reflected in response
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ **الدليل (Evidence)**

```
External URL reflected in response
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Food+%26+Drink"
```

💥 **التأثير المحتمل**

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ **كيفية الإصلاح**

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

📚 **مراجع إضافية**

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

ثغرة رقم 28

Open Redirect

الخطورة: **منخفضة** | الثقة: **0%** | الفئة: **عام**

📖 وصف الثغرة

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle
```

2

التحليل

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

2

الدليل

```
External URL reflected in response
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ الدليل (Evidence)

```
External URL reflected in response
```

💻 أمر cURL للإعادة

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Lifestyle"
```

💥 التأثير المحتمل

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ كيفية الإصلاح

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

📚 مراجع إضافية

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

ثغرة رقم 29

Open Redirect

الخطورة: منخفضة | الثقة: 0% | الفئة: عام

📖 وصف الثغرة

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

🎯 الهدف المصاب

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

🚀 خطوات الاستغلال

1

اكتشاف الثغرة

تم اكتشاف الثغرة أثناء الفحص الآلي.

الهدف

```
https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets
```

2

التحليل

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

2

الدليل

```
External URL reflected in response
```

3

التأثير

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

⚠️ **الدليل (Evidence)**

```
External URL reflected in response
```

💻 **أمر cURL للإعادة**

```
curl "https://0a650022042123ab80198a0b00070026.web-security-academy.net/filter?category=Pets"
```

💥 **التأثير المحتمل**

قد يؤدي استغلال هذه الثغرة إلى تعريض أمن التطبيق والبيانات للخطر.

✅ **كيفية الإصلاح**

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

📚 **مراجع إضافية**

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html